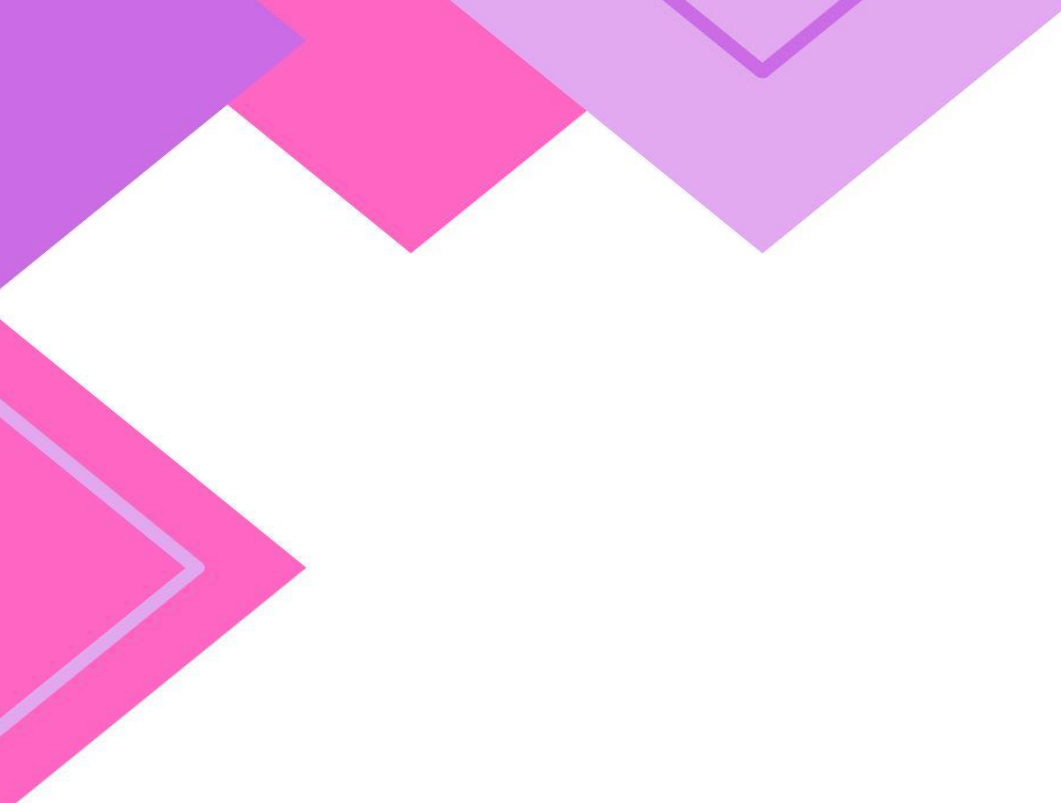
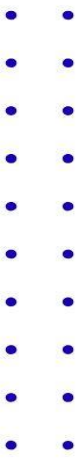


ETHICAL HACKING AND INFORMATION SECURITY ASSESSMENTS

BLUE CROSS HOSPITAL

AUTUMN 2026



Name: Min Hein Kyaw

Student ID: 218542

Name of the Centre: Twinkle College

Total word count – 4394 words



Contents

Preface.....	4
Task 1	5
a) Static and dynamic malware analysis	5
Malware analysis.....	5
Offline Static analysis	5
Offline Dynamic analysis	7
b) Type of attack	9
Spear phishing	9
Defense strategies	9
Task 2	11
a) Vulnerability affecting management system	11
CVE-2019-20183.....	11
Steps to exploit vulnerability	12
b) Service running on default port 161	18
Simple network management protocol.....	18
Countermeasures.....	19
Task 3	21
a) Identify server's operating system.....	21
Methods	21
Packet characteristics	23
b) Penetration testing against FTP server and countermeasures	25
File Transfer Protocol (FTP)	25
Wireshark	25
Packet sniffing penetration testing against FTP server with Wireshark tool	26
Countermeasures.....	30
Task 4	32

a) Vulnerability which can gain administrative privileges	32
Unquoted service path.....	32
DLL Hijacking	32
Privilege escalation	32
Security impact.....	33
Countermeasures.....	33
b) Hospital's online reputation and footprinting.....	34
Monitoring methods.....	34
Tracking tools.....	35
Footprinting	36
Conclusion	37
References.....	38

Preface

Blue Cross hospital stores medical and financial information of hundreds of patients and clients. It uses medical equipment such as computers, IOT devices for everyday business operations. They want to perform information security assessment to reduce identified risks and maintain existing certifications and good reputation.



Fig 1– Cyber attack (magnific, 2026)

Task 1

a) Static and dynamic malware analysis

Malware analysis

Malware analysis means examining suspicious file(**payment_invoice.pdf.exe**) to determine its origin and potential effect on system. Before analysis, effected system(finance manager's computer) must be isolated both physically and logically from network to prevent spreading around all medical equipment in hospital(lateral movement).

(MadhukarRaina, 2026)

Offline Static analysis

Static analysis means examining suspicious file(**payment_invoice.pdf.exe**) without executing it. It identifies malicious characteristics by inspecting file's structure, metadata, strings, imports and code patterns.

Workflow

1. Isolate and identify file type

Suspicious file is copied to offline forensic system and confirmed that it is actually a program pretending to be document by viewing file header (**payment_invoice.pdf.exe**) with file-type identification tools. It is found that **payment_invoice.pdf.exe** is double extension in file name. So, it is not a pdf file and is an executable program.

2. Calculate cryptographic hashes

Cryptographic hashes are used as unique fingerprints for comparison with known malware records. SHA-256, MD5, and SHA-1 hashing algorithms can be used. But SHA-256 should be primary hash as it is more compatibility with older security tools and malware databases. So, more comparisons can be used and more chances can be found.

3. Extract readable strings

URLs, IP addresses, email, file paths, commands and references such as powershell.exe are being searched by using Strings and BinText. It is used to find however that suspicious file can communicate with another server or download additional payload. It can identify attacker accounts or data-exfiltration destinations.

4. Detect packing or obfuscation

The suspicious file is detected by using packer-detection tools such as PEiD however it has been compressed, encrypted or protected to hide its real code and evade antivirus detection.

5. Examine imported DLLs and API functions

It identifies however program has intended capabilities such as networking, file creation, process injection, registry modification or command execution by using PE analysis tools and import table inspection.

6. Disassemble or decompile program

Program is decompiled for inspecting its instructions and logic to identify malicious routines, anti-analysis techniques, persistence mechanisms and data-stealing functionality by using Ghidra and IDA.

(geeksforgeeks, 2025) (geeksforgeeks, 2026) (Dimitris, 2024)

Offline Dynamic analysis

It means executing suspicious file(**payment_invoice.pdf.exe**) in controlled and isolated environment(virtual machine) which is not connected to network. It can observe file's real-time behavior including process creation, registry changes, file drops and network communication. It can show behavior which may not be visible through offline static analysis.

Workflow

1. Prepare isolated virtual machine

The virtual machine must be disabled shared folders, clipboard sharing, drag-and-drop, USB passthrough and network access.

2. Take clean Virtual Machine snapshot

Safe restore point is created. So, virtual machine can be rolled back after testing.

3. Start monitoring tools

Before execution, process, files, folders, registry, service, API calls, event-log, ports and network monitoring are activated.

4. Execute suspicious sample

After preparation of isolated virtual machine and monitoring tools, the file is run in that virtual machine.

5. Observe system activities

Files, registry and system activities can be monitored by Process Monitor (Procmon). Process Explorer can be used to monitor running processes. Autoruns can be used to monitor startup, services and Wireshark can be used to monitor DNS, HTTP, TCP/UDP and packets.

TCPView can show ports and live connections. API monitor can show API calls and logs can be viewed by using Event viewer. Debugger tools such as Immunity or Olly debugger can be used to debug instruction and function tracing during runtime.

6. Record observations

Then, virtual machine system is documented before, during and after states to identify immediate and delayed behavior. For example, files dropped into Temp, Startup or system directories are suspicious and they can be unexpected communication with unknown external systems.

7. Revert Virtual Machine

After analysis, the clean snapshot is restored to remove changes made by suspicious file(**payment_invoice.pdf.exe**). So, the virtual machine is now the original state and can be used cleanly.

(Dimitris, 2024) (ScienceDirect, 2014) (Damodaran, 2015)

b) Type of attack

Spear phishing

The finance manager is attacked by spear phishing type (social engineering) as the email was carefully designed and specifically aimed at finance manager. The attacker used real client name, business information or other relevant details to pretend to be a real client to get finance manager's trust and made email appear real.

The email contained a file extension virus (**payment_invoice.pdf.exe**) which can be malicious. The attacker goal can be to steal financial information, install malware or gain unauthorized access to Blue Cross private hospital's network.

(Kosinski, 2024)

Defense strategies

1. Security awareness training

Employees are trained to know about suspicious attachments, spoofed email addresses and social engineering techniques such as shoulder surfing, tailgating, phishing and impersonation. They will be learnt about psychological triggers such as urgency, fear, authority, helpfulness and greed which are commonly used in social engineering.

Gap analysis can find which employee is weak in security awareness. For example, the penetration tester sends phishing email with malicious file into hospital team. Employees who open this email and open malicious file will receive additional training.

(SentinelOne, 2026)

2. Email security controls

Spam filtering, attachment analysis, malware scanning and authentication controls such as SPF (Sender Policy Framework) , DMARC (Domain-based Message Authentication, Reporting, and Conformance) and DKIM (DomainKeys Identified Mail) can be used in email gateways to prevent malicious attack through email.

For example, attacker sends an email by pretending as real client. DMARC detects that sending server is unauthorized and then quarantines the message. So, these email security controls can block spoofed emails and malicious files before reaching employee's inbox. These acts as second line defense although attackers can pass through hospital employees by social engineering.

(Cloudflare, 2026)

3. Endpoint protection and backup

Antivirus, antimalware, EDR (Endpoint Detection and Response), application control and device isolation tools are used to monitor endpoints for malicious activities. For example, when malicious file(**payment_invoice.pdf.exe**) tries to run script and connect to command-and-control server, EDR can detect that behavior and isolate that computer from network.

Multi-factor authentication should also be used because even attacker can get password, he cannot enter into system. MFA reduces risk of account compromise when credential information is stolen through phishing and malware. Regular backups for important hospital data are also required. So, even malware(ransomware) encrypts files on finance manager's computer, hospital can restore data from protected backup.

(NCSC, 2026)

Task 2

a) Vulnerability affecting management system

Network and vulnerability scans of hospital's network show that management system have vulnerability of **CVE-2019-20183**.

CVE-2019-20183

CVE-2019-20183 means the system is vulnerable in file upload validation (**CWE-434 : Unrestricted Upload of File with Dangerous Type**). It can affect in employee records management system v1.0. Common vulnerability scoring system (CVSS) base score is 7.2 and so the severity rating is high.

This happens because the system only uses global.js validation logic on client side to verify files and does not verify them from server side. So, the server does not know that uploaded file is safe or permitted. The attacker can bypass it by using interception proxy tools such as Burp Suite. Then, he uploads malicious PHP file into server to make remote code execution (RCE). After making RCE, attacker can install reverse shell to maintain access and execute commands on compromised server.

Successful exploitation can result in complete compromise of the hospital system. Patient information can be stolen, altered or deleted. The compromise server can be used as entry point to access other systems within hospital's internal network (lateral movement). It can cause system downtime, delays and disruption to Blue Cross hospital's services.

(nvd.nist, 2026)

Steps to exploit vulnerability

Step 1 - Initiate workflow

The attacker opens the Blue Cross Hospital page where employee details can be changed or added. (OxPablito, 2020)

test test

GPS Location of Residence
test

Direction to Residence
test

Upload Employee Photo

shell.php **UPLOAD**

Unsupported file type. Files should be either .jpeg, .jpg, .png

Upload Employee ID

National ID Number: 12 National ID type: Voter's

Upload Selected ID type **UPLOAD**

Next of Kin Data

Full Name: test Relationship to employee: test

Phone number: 123 Residential Address: test

Fig 2.1 - Open the page and analyze in detail (OxPablito, 2020)

Step 2 - Intercept traffic

The attacker uses interception proxy such as Burp Suite to check file-upload workflow and validation process. (OxPablito, 2020)

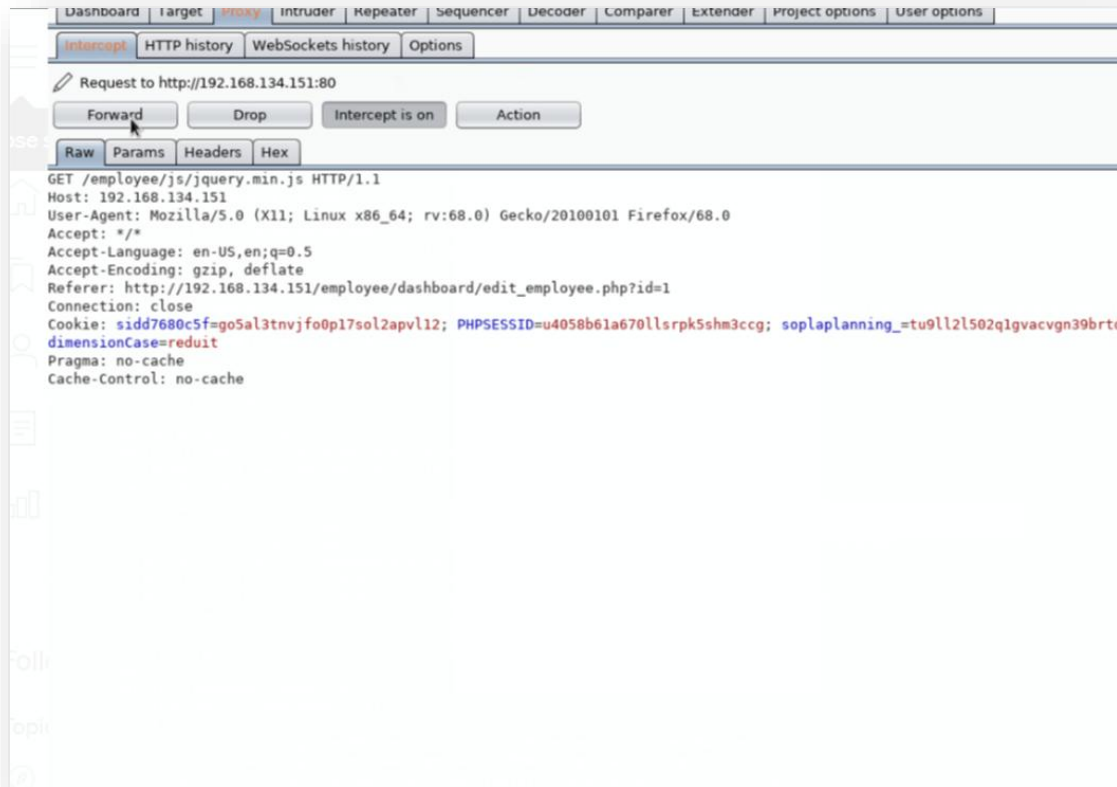
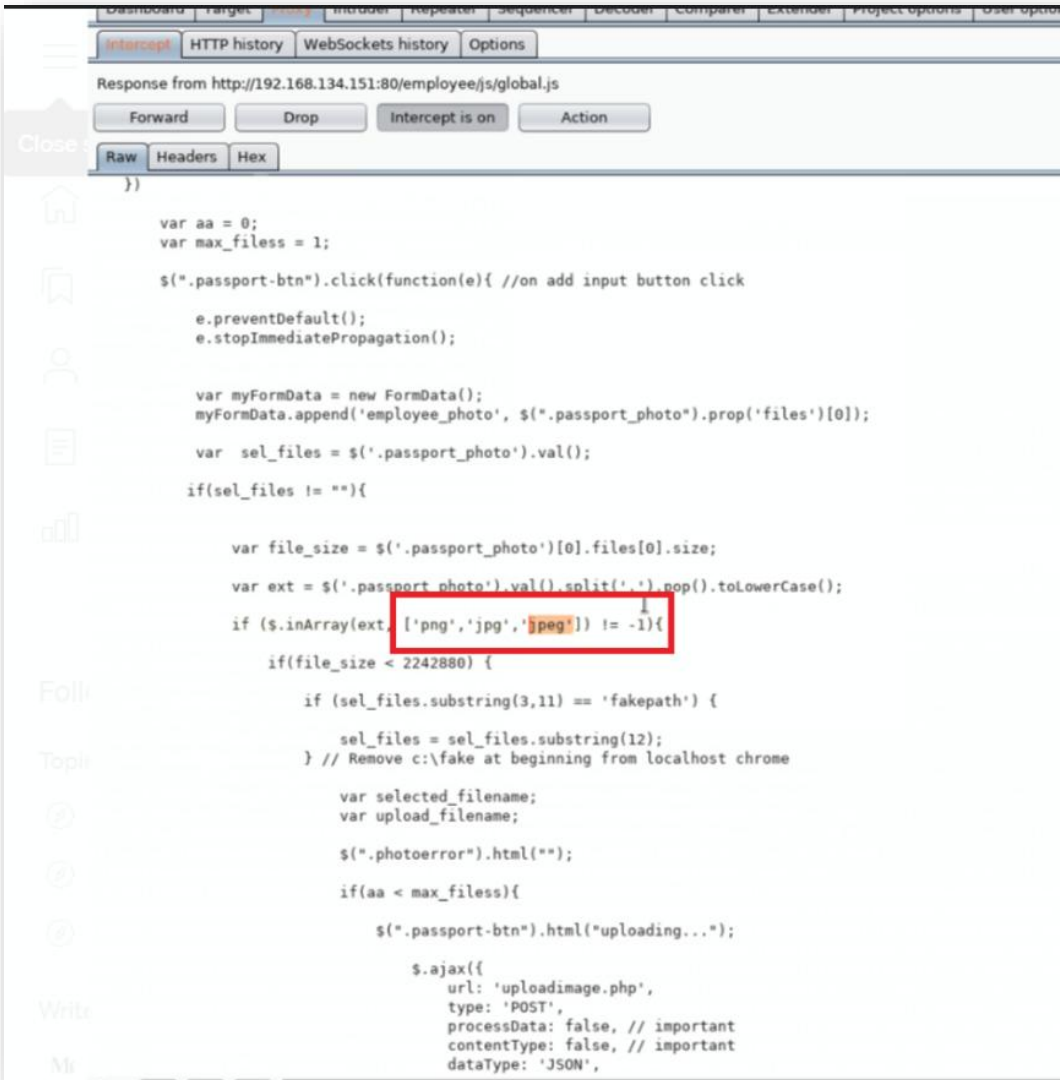


Fig 2.2 - Use Burp Suite to intercept the traffics (OxPablito, 2020)

Step 3 – Found global.js

The attacker intercepts global.js which is used as validation at client-side only when analyzing the traffic. (OxPablito, 2020)



```
var aa = 0;
var max_files = 1;

$(".passport-btn").click(function(e) { //on add input button click

    e.preventDefault();
    e.stopImmediatePropagation();

    var myFormData = new FormData();
    myFormData.append('employee_photo', $(".passport_photo").prop('files')[0]);

    var sel_files = $(".passport_photo").val();

    if(sel_files != ""){

        var file_size = $(".passport_photo")[0].files[0].size;

        var ext = $(".passport_photo").val().split('.')
        .pop().toLowerCase();

        if ($.inArray(ext, ['png', 'jpg', 'jpeg']) != -1){

            if(file_size < 2242880) {

                if (sel_files.substring(3,11) == 'fakepath') {

                    sel_files = sel_files.substring(12);
                } // Remove c:\fake at beginning from localhost chrome

                var selected_filename;
                var upload_filename;

                $(".photoerror").html("");

                if(aa < max_files){

                    $(".passport-btn").html("uploading...");

                    $.ajax({
                        url: 'uploadimage.php',
                        type: 'POST',
                        processData: false, // important
                        contentType: false, // important
                        dataType: 'JSON',
```

Fig 2.3 – Found PHP files are not permitted (OxPablito, 2020)

Step 4 - Bypass client-side validation

The attacker modifies client-side global.js validation logic. Then, PHP files can be uploaded as they get permission. (OxPablito, 2020)

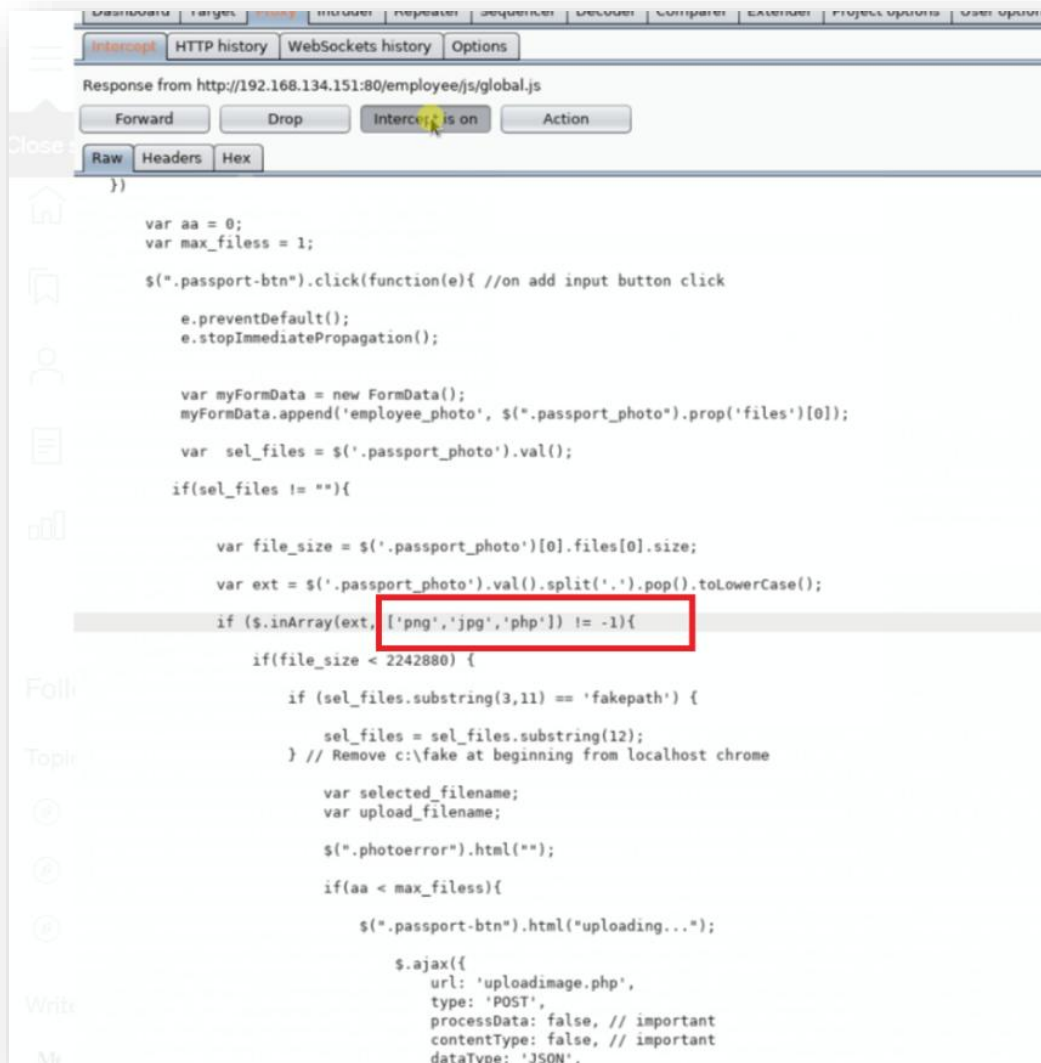


Fig 2.4 – Modify global.js validation logic (OxPablito, 2020)

Step 5 - Upload malicious PHP file

The attacker creates malicious PHP file and uploads it through vulnerable upload functionality. (OxPablito, 2020)

The screenshot shows a web form with several sections. The first section contains four input fields: 'Residential Address' (test), 'Location of Residence' (test), 'GPS Location of Residence' (test), and 'Direction to Residence' (test). Below this is the 'Upload Employee Photo' section, which has a text input field containing 'shell.php' and an 'UPLOAD' button. This section is highlighted with a red rectangle. Below that is the 'Upload Employee ID' section, which has two input fields: 'National ID Number' (12) and 'National ID type' (Voter's), followed by an 'Upload Selected ID type' field and an 'UPLOAD' button. The final section is 'Next of Kin Data', which has two input fields: 'Full Name' (test) and 'Relationship to employee' (test). At the bottom, there are partially visible labels for 'Phone number' and 'Residential Address'.

Field	Value
Residential Address	test
Location of Residence	test
GPS Location of Residence	test
Direction to Residence	test
Upload Employee Photo	shell.php
National ID Number	12
National ID type	Voter's
Upload Selected ID type	
Full Name	test
Relationship to employee	test

Fig 2.5 – Upload malicious PHP file (OxPablito, 2020)

Step 6 - Trigger execution

The attacker opens uploaded malicious PHP file through web browser. Then, server runs hidden PHP code. Finally, the attacker can control the target Blue Cross hospital system remotely by reverse shell. (OxPablito, 2020)

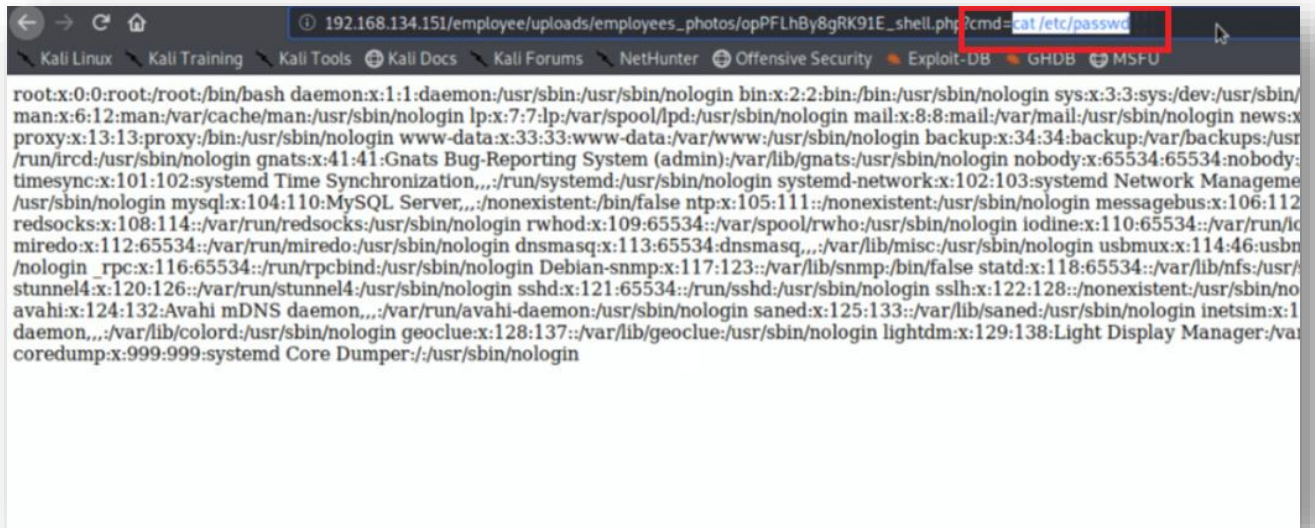


Fig 2.6 – Get remote access through web browser (OxPablito, 2020)

b) Service running on default port 161

After scanning of Blue Cross Hospital, it is found that default port 161 is open and service is running on it. By researching about port 161, the service running on it is SNMP (Simple network management protocol).

Simple network management protocol

Description

SNMP runs on default port 161 to receive queries and management requests. It uses transport protocol UDP. It is used to monitor and manage routers, switches, servers, printers, firewalls and other network devices. If SNMP is misconfigured, it can expose sensitive device and network information.

SNMP works as manager and agent. SNMP manager acts as central monitoring system which sends requests to managed devices (SNMP agents) that receive requests and returns information. It uses management information base (MIB) which contain information about managed devices. It uses object identifier (OID) to locate specific object within MIB.

SNMP uses requests such as GetRequest, GetBulkRequest to manage the MIB tree. For access control, it uses public (read-only) and private (read-write) community strings. In version 1 and version 2 of SNMP, community strings are used as shared passwords and transmitted without encryption. So, if attacker can enter into hospital network, he can view system, network information and modify configurations.

(Presuhn, 2002) (Harrington, 2022)

Tools

The attacker usually uses enumeration tools such as Nmap, snmpwalk, snmpbulkwalk, snmpget, snmp-check and onesixtyone to enumerate information through UDP port 161 (SNMP). For example, Nmap can be used to find that UDP port 161 is open on target device and it can also run SNMP related NSE scripts for service discovery and enumeration.

(Presuhn, 2002)

Information obtainable from Blue Cross hospital

The attacker can get hospital devices' identification such as hostname, device name, vendor and system description. He can know about hospital devices' operating system such as OS type, software version, firmware version and system architecture. He can view hospital's network interfaces such as interface names, IP addresses, MAC addresses and status. He can know about hospital's network configuration such as DNS information, subnet masks and gateways. He can find routing information (routing tables, routes), ARP information, services (active services, running services), user-related information and devices information (e.g. printer information) of the hospital.

(Presuhn, 2002)

Countermeasures

1. Disable SNMP

SNMP should turn off when it is not required in hospital to remove attack surface completely.

2. Restrict port 161

UDP port 161 is restricted by using network and host firewalls to prevent unauthorized external queries.

3. Apply access control lists (ACLs)

Hospital permits only SNMP traffics from approved management systems by using ACLs. So, it can block unauthorized devices.

4. Remove default community strings

Public and private community strings are replaced with strong and unique custom strings which are defined by hospital. It reduces the risks of credential attacks.

5. Use SNMP version 3

SNMP version 3 has authentication, integrity protection and encryption. It can protect credentials and manage traffics and also provide strongest standard security level.

6. Disable write access

Write access is disabled when it is unnecessary and read-only is permitted only for monitoring systems. So, it can prevent unauthorized configuration changes in hospital's SNMP.

7. Configure SNMP views and use least privilege

Hospital employees can access only parts of required SNMP management information base that they need. So, it can minimize the amount of exposed information and limit damage.

8. Monitor SNMP activities

SNMP queries, failures, configuration changes and unusual scanning are recorded to detect attack early.

9. Update SNMP services

Hospital's device firmware and SNMP software are regularly updated to reduce exposure to known vulnerabilities.

10. Avoid public access and remove anonymous access paths

SMNP should not be exposed to public directly by internet to prevent remote scanning and enumeration of hospital network.

The services that allow access without valid username, password or authentication key are disabled to prevent unauthorized reconnaissance.

(Schoenwaelder, 2008) (Blumenthal, 2002) (Presuhn, 2002)

Task 3

a) Identify server's operating system

Blue Cross hospital FTP server's OS is not known. So, the following methods can be used to identify OS.

Methods

1. Active banner grabbing

Active banner grabbing means directly connecting to FTP service to know its responses. It connects FTP port 21 and reads 220 greeting banners. For example, when scanner sends **SYST** (FTP command), the server normally responds **215 UNIX Type: L8** (Banner). So, the FTP server uses Unix-style file system.

Active banner grabbing is simple, fast and can show FTP software, version and OS but it is noisy and easily detected by IDS/IPS systems. Banners can be also hidden, modified or faked.

(geeksforgeeks, 2025)

2. Passive banner grabbing

Passive banner grabbing means collecting service information which are already flowing in traffics without directly sending requests to targets. It can collect logs, cached scan results, network captures and metadata.

It is stealthier than active banner grabbing and so less chance to trigger security alerts. But it requires access to existing traffic and results can be incomplete, encrypted and hidden.

(Borges, 2024)

3. Active OS fingerprinting

Active OS fingerprinting means sending specially crafted packets to study how target responds. For example, Nmap can be used to run **nmap -O <IP>** and compare TCP/IP responses with its fingerprint database.

It can estimate OS family, device type, kernel and OS version. But it sends noticeable network traffic to target and so it can trigger security alerts of target system. It is also inaccurate when firewalls are present between client and server.

(Shinde, 2025)

4. Passive OS fingerprinting

Passive OS fingerprinting means identifying OS by analyzing normal traffic which are already travelling in network. For example, Wireshark can be used to inspect TTL, TCP window size, IP ID behavior, flags and TCP options.

Passive OS fingerprinting does not send traffics to target and so it is stealthier than active OS fingerprinting. But it requires visible to network traffic as NAT, proxies, firewalls and VPN tunnels can hide or alter packet characteristics.

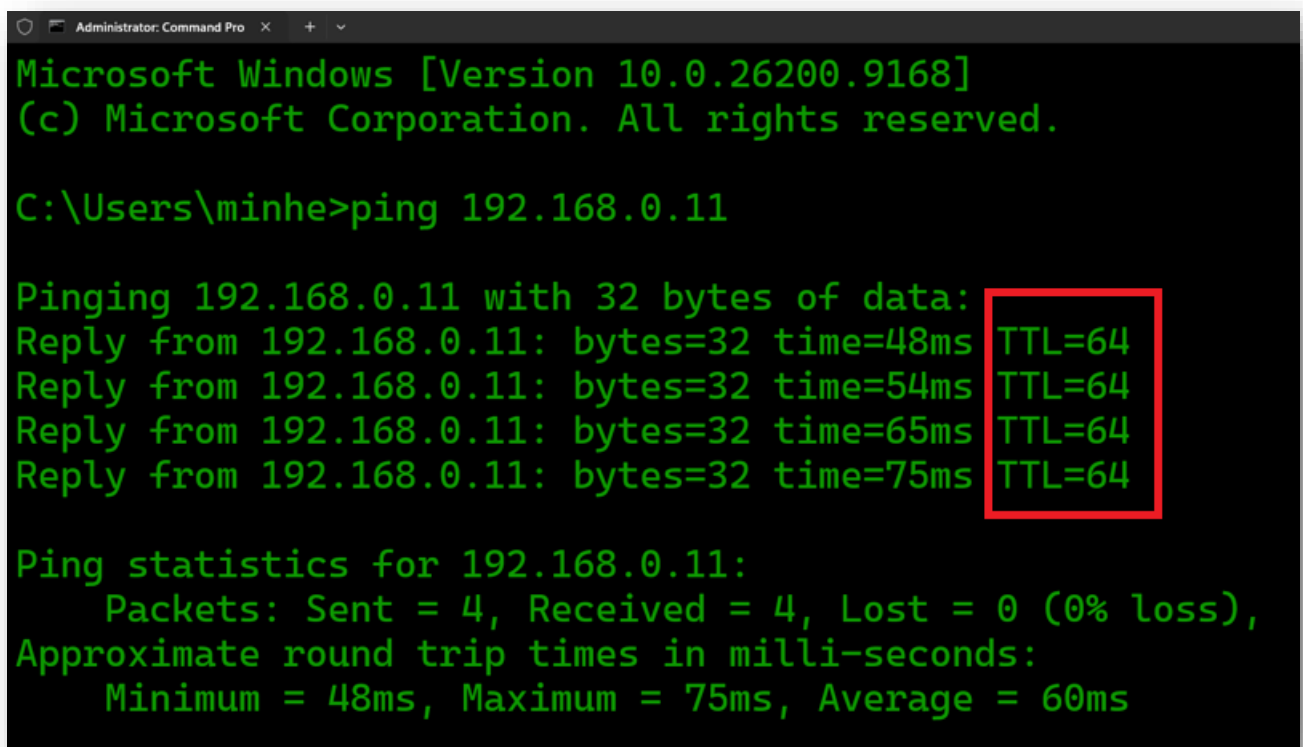
(Edwards, 2022)

Packet characteristics

Time to live (TTL)

TTL limits how many routers that IP packet can cross. Linux systems start near 64 and window systems start near 128. Routers and network devices start near 255. The observed TTL is usually lower than original value because each router decreases it by one and TTL only cannot confirm OS.

(Rocca, 2024)



```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.26200.9168]
(c) Microsoft Corporation. All rights reserved.

C:\Users\minhe>ping 192.168.0.11

Pinging 192.168.0.11 with 32 bytes of data:
Reply from 192.168.0.11: bytes=32 time=48ms TTL=64
Reply from 192.168.0.11: bytes=32 time=54ms TTL=64
Reply from 192.168.0.11: bytes=32 time=65ms TTL=64
Reply from 192.168.0.11: bytes=32 time=75ms TTL=64

Ping statistics for 192.168.0.11:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 48ms, Maximum = 75ms, Average = 60ms
```

Fig 3.1 – Linux systems start near TTL=64

```
Administrator: Command Prompt
C:\Users\minhe>ping 192.168.0.105

Pinging 192.168.0.105 with 32 bytes of data:
Reply from 192.168.0.105: bytes=32 time=115ms TTL=128
Reply from 192.168.0.105: bytes=32 time=25ms TTL=128
Reply from 192.168.0.105: bytes=32 time=4ms TTL=128
Reply from 192.168.0.105: bytes=32 time=5ms TTL=128

Ping statistics for 192.168.0.105:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 4ms, Maximum = 115ms, Average = 37ms
```

Fig 3.2 – Window systems start near TTL=128

TCP window size and TCP options

TCP window size shows how much data host can receive before requiring acknowledgement. Different OS has different default window sizes. For example, Windows has 64240, Linux has 29200 and older systems have 65535. TCP options such as MSS, SACK, Window Scale, timestamps and their ordering can identify OS.

(Rocca, 2024)

b) Penetration testing against FTP server and countermeasures

Second network scanning of Blue Cross hospital shows that hospital is using File Transfer Protocol (FTP) server which allows employees to use usernames and passwords for authentication, uploading and downloading specific files easily.

File Transfer Protocol (FTP)

FTP is used for plain-text communication because network traffics are not encrypted. It can be used as data channel to transfer files. It uses TCP port 21 for authentication and commands such as **USER** and **PASS**. So, FTP traffics can be captured and analyzed by packet sniffing tools such as Wireshark.

(securityscorecard, 2025)

Wireshark

Wireshark is used for network protocol analysis. It can capture and display network packets, protocol information, headers and raw data. If promiscuous mode is enabled, it can capture all traffics which are visible on network segments. It contains also functions such as display filters and follow TCP stream. It is commonly used in network troubleshooting, education, security investigation and authorized penetration testing.

(sophos, 2026)

Packet sniffing penetration testing against FTP server with Wireshark tool

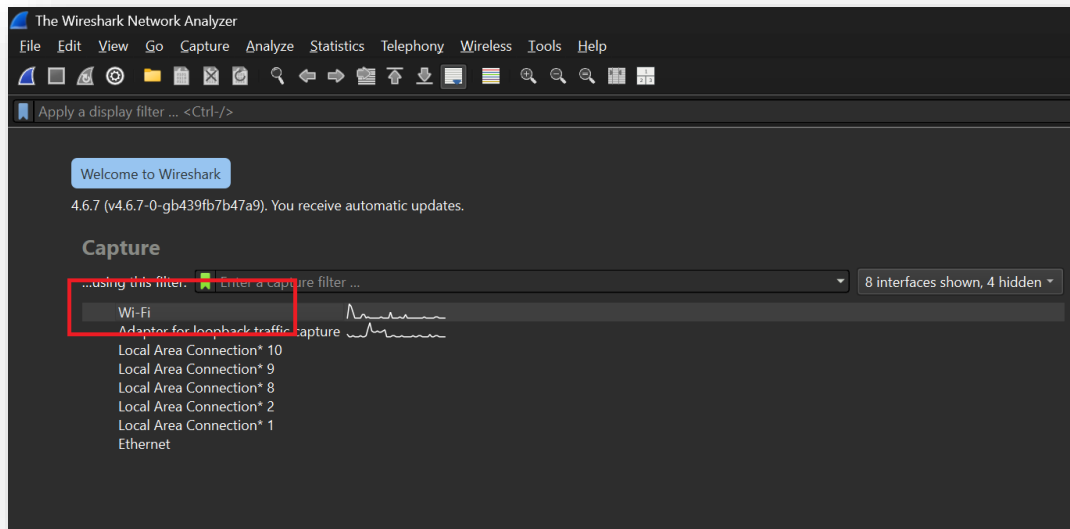


Fig 3.1

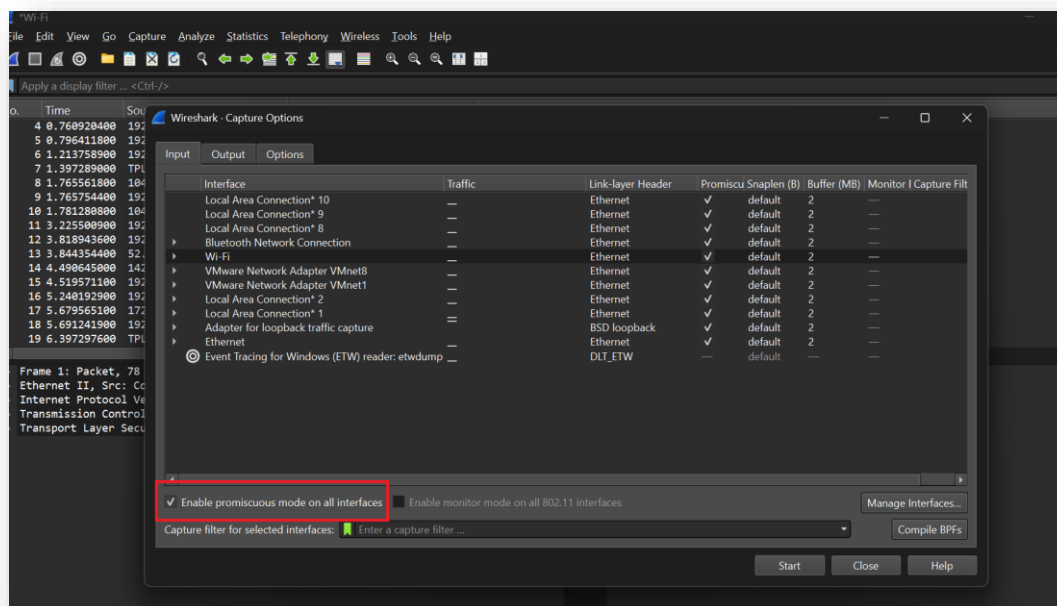


Fig 3.2

Wireshark tool is opened and correct network interface is selected. Then, promiscuous mod is enabled. It allows network adapter to capture frames which are visible on network segment.

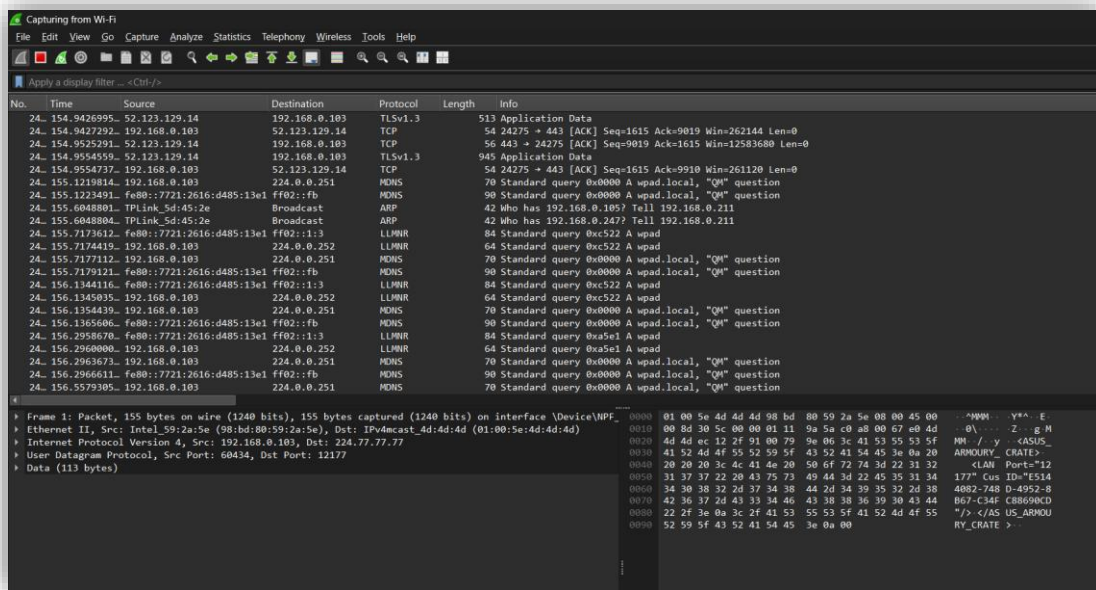


Fig 3.3

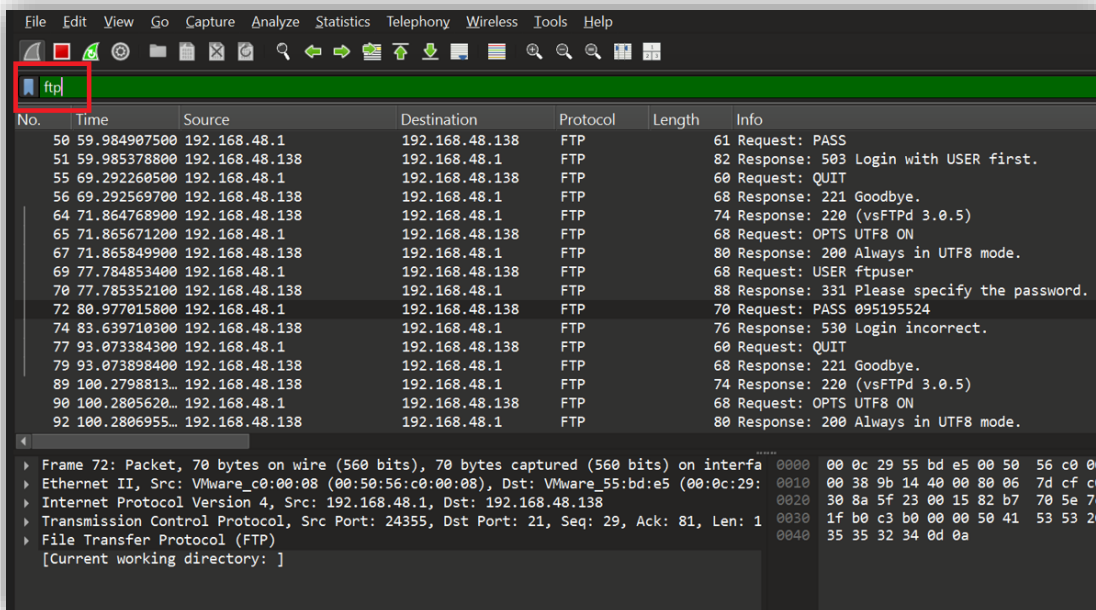


Fig 3.4

The attacker waits for hospital employee's authentication to FTP server. The Wireshark can be used to filter ftp traffic on its display. It can isolated FTP traffic from unwanted other network traffic.

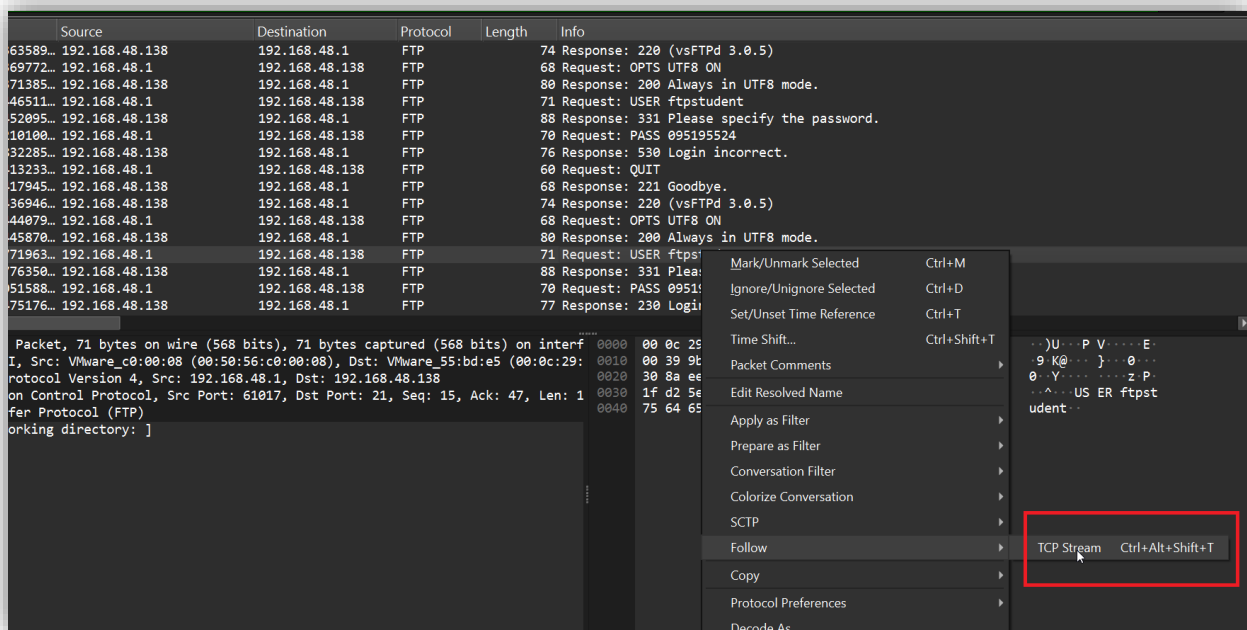


Fig 3.5

Individual FTP packets (commands and server responses) are inspected. Then, targeted FTP packet is right-clicked and **Follow** button is selected to show **TCP Stream**. It reconstructs FTP conversation in readable format.

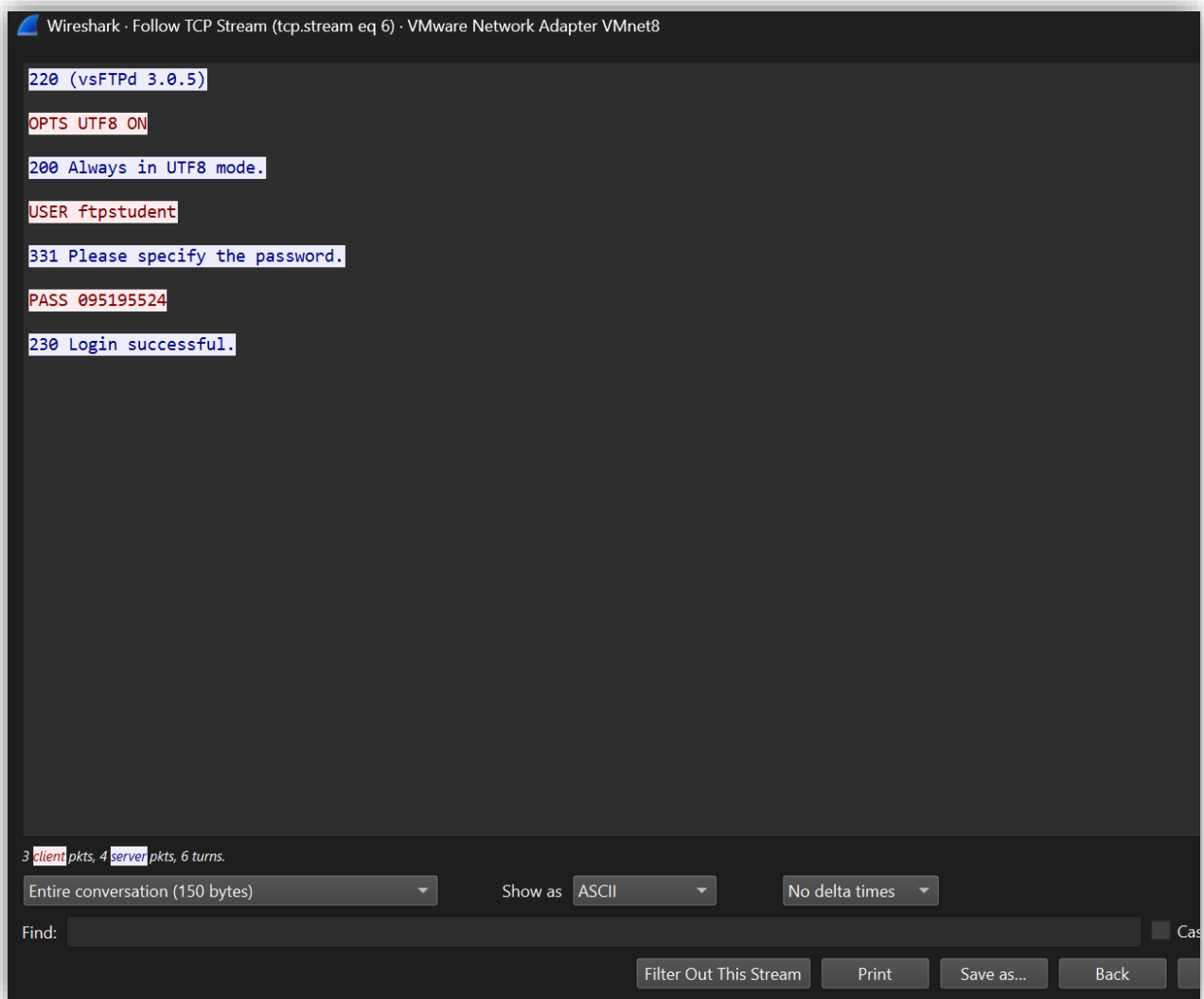


Fig 3.6

Then, commands such as **USER** and **PASS** are searched because standard FTP exposes usernames and passwords in plain text. FTP data-channel traffics and transferred files are also examined as file contents can be visible that FTP does not encrypt its data channel. Then, the attacker can get exposed credentials, document and sensitive data.

(Hanna, 2024) (sysdig, 2026) (Hegde, 2020)

Countermeasures

1. Use SFTP instead of FTP

SFTP is Secure File Transfer Protocol which is operating over SSH. It encrypts authentication credentials, commands and transferred files.

2. Use FTPS instead of FTP

FTPS is traditional FTP which is protected by using SSL/TLS. It can encrypt FTP control and data channels when it is well configured.

3. Use SCP instead of FTP

SCP is Secure Copy Protocol which is operating over SSH. It provides encrypted files in transferring between systems.

4. Place FTP traffics inside VPN

VPN is encrypted network tunnel which can prevent attackers on the network from reading FTP session easily.

5. Use IDS/IPS (Intrusion Detection System/Intrusion Prevention System)

It can detect ARP spoofing, abnormal authentication attempts, scanning and other suspicious activities.

6. Disable plain FTP

Standard FTP should be removed if it is possible. So, the hospital can eliminate main source of plain text FTP credential exposure.

7. Use strong authentication

Strong passwords, SSH keys and multifactor authentication should be used. So, it can reduce the risk of unauthorized access by attackers.

8. Segment Network

Network segmentation means dividing network into smaller and separate sections. File transfer servers are placed in trusted network zone where approved devices or users are only allowed to connect.

9. Monitor network

Authentication logs, file transfer activities and traffic patterns are monitored. So, It can give early detection of unusual access or data transfer behavior.

10. Use Sniffing detection techniques

Sniffing detection techniques such as promiscuous mode detection, ARP monitoring, DNS monitoring, ping and discovery monitoring, switch monitoring, authentication monitoring can be used.

(V., 2025) (Cucias, 2025) (eccouncil, 2022) (okta, 2024)

Task 4

a) Vulnerability which can gain administrative privileges

When enumerating the doctors' computers which run Windows 10 in Blue Cross hospital, it is found that patient app service can run with system privileges and is also vulnerable to unquoted service path.

Unquoted service path

Unquoted service path means service executable path contains spaces but is not enclosed in quotation marks. In Blue Cross private hospital, Patient App executable is located at **C:\program files\myPatientApp.exe**. So, it is without quotation marks and windows can interpret path incorrectly and check locations such as **C:\program.exe** before reaching the real executable(**C:\program files\myPatientApp.exe**). (Waterman, 2023)

DLL Hijacking

DLL Hijacking happens when application loads DLL from unsafe or user-writable location instead of intended trusted library. This can happen when **myPatientApp.exe** loads DLL by relative path rather than using secure absolute path and Windows' DLL search order checks application's directory early in sequence. (Liford, 2013)

Privilege escalation

As Patient App service can run with SYSTEM privileges, the attacker can be able to escalate privileges by placing malicious executable at **C:\program.exe** or placing malicious DLL such as **example.dll** in writable directory searched by Patient App and then wait for the doctors to run the Patient App.

When Patient App starts, it causes malicious executable or DLL to run with SYSTEM privileges. But these exploitations require standard user to have permission to create executable file at locations that window checks. (Verma, 2019)

Security impact

As Patient App runs as SYSTEM, code executed through vulnerable service can cause SYSTEM-level privileges. This can significantly increase consequences of local compromise such as unauthorized access to sensitive patient information, malware installation and full workstation compromise.

Countermeasures

1. Quoting service paths

The complete executable path is quoted and then it prevents ambiguity which is caused by spaces. In Blue Cross hospital, Patient App service path is changed to **"C:\program files\myPatientApp.exe"**.

2. Least privilege

Services should run with only privileges required for their function. In Blue Cross hospital, Patient App should not run as SYSTEM unless it is necessary.

3. Permission reviews

File and directory ACLs determine that standard users can change service-related files. So, permissions on **C:\program files**, Patient App directory, executable and related libraries should be reviewed. Tools such as Sysinternals AccessChk can be used to identify Write, Modify or Full Control permissions which are granted to inappropriate users. So, standard users should have only permissions to run application such as Read and Execute.

4. Analysis with Procmon Tool

Sysinternal Process Monitor (Procmon) can observe file-system activities without exploiting vulnerability. So, myPatientApp.exe is monitored during service startup to determine where it searches for DLLs and other files.

(Belisari, 2025) (Freeborn, 2026)

b) Hospital's online reputation and footprinting

For Blue Cross hospital, online reputation management is important. It means continuous monitoring, analysis and improvement of how patients, staff, journalists and public perceive hospital online. It helps to protect public trust, patient choice and community confidence.

(Sharma, 2026)

Monitoring methods

1. Search engine monitoring

Search engine monitoring means regularly checking search results for hospital name, senior staff and major services such as emergency care. It helps to identify negative news, patient reviews, misinformation and online discussions.

2. Social media monitoring

Social media monitoring means tracking news, comments, engagement and mentions on platforms such as Twitter(X), LinkedIn and Facebook. It can identify complaints, misinformation and public reactions to incidents in real time.

3. Threat intelligence monitoring

Threat intelligence monitoring means monitoring cybersecurity information that can damage hospital's reputation such as data breach reports, leaked patient information, dark web activities and security alerts which involve hospital domains or IP addresses.

(Henry, 2026) (Kati, 2022) (Worrall, 2025)

Tracking tools

1. Google analytics and alerts

Google analytics is used to measure website visitors, page views, traffic sources and user behavior. It can help to determine which reputation incidents are affecting hospital website traffic.

Google alerts can send notifications when new online content mentions about hospital, executives, services or keywords such as “data breach”.

2. Shodan

Shodan can be used to identify publicly exposed internet-connected systems and services that can create reputational risks.

3. Maltego

Maltego can be used to map relationships between domains, people, email addresses, organizations and infrastructure to support footprinting.

4. SIEM (Security Information and Event Management)

SIEM is used to connect different pieces of information together such as suspicious login, malware, failed access attempts, suspected leaks, unauthorized access and public complaints to help security team react quickly and manage the incident.

5. Online Monitoring Tools

Online monitoring tools such as Birdeye, ReviewTrackers, Hootsuite, Amazon tracking statistics and Trakur can be used to aggregate reviews, social media mentions, customer feedback and online discussions into centralized dashboards for monitoring and responding quickly.

(Javelly, 2023) (talkwalker, 2024) (Aggarwal, 2025)

Footprinting

Footprinting means authorized and systematic collection of information about organization. It is a part of reconnaissance stage of security assessment. It has passive footprinting and active footprinting.

Passive footprinting means collecting information without directly interacting with the target system. For example, the target organization's information is being searched in google searches, company website, LinkedIn, WHOIS records and public DNS information.

Active footprinting means collecting information by directly interacting with the target. For example, the target organization's information is being searched by using ping, traceroute, DNS queries, port scanning and banner grabbing.

So, Blue Cross hospital can see their network from attacker's perspective and identify information exposed to public internet.

(avon, 2026)

Attacker footprinting

By footprinting, attacker can identify forgotten websites, development systems, test environments or other possible entry points. He can find staff information such as names, job roles, email addresses and email formats. He can collect it and later use for phishing or social engineering attacks. He can also identify software, operating systems, web frameworks and versions to find vulnerability.

(eccouncil, 2022)

Defensive footprinting

By footprinting, Blue Cross hospital can identify forgotten systems, unauthorized services, exposed databases or old VPN portals. So, they can removed unnecessary services, accounts, systems, DNS records and publicly available information. So, footprinting can improve security posture of the Blue Cross private hospital by prioritizing patching, improving configuration, strengthening monitoring and updating incident-response procedures.

(sencode, 2026)

Security benefit

Footprinting is used to understand which domains, IP addresses, servers, applications and services belong to Blue Cross private hospital. Internet facing and high-risk assets can be identified and prioritized for vulnerability assessment to remove or reduce security weakness. It can also defense phishing by identifying publicly available employee information. So, Blue Cross hospital can understand what attacker could use in social engineering attacks.

(staff, 2026)

Conclusion

In Blue Cross hospital, there was a spear phishing attack which aimed to finance manager. There was also a vulnerability(**CVE-2019-20183**) and there is port 161 running in system(SNMP protocol). FTP server should not be opened as it has high security risks.

There is also vulnerability such as unquoted service path and it should be handled carefully. Attacker can also investigate server's OS. So, methods and characteristics of about it should also be understood.

Blue Cross private hospital should also take care of their online reputation and about footprinting to improve their reputation and security.

-----End of the Assignment-----

References

Aggarwal, B., 2025. *sprinklr*. [Online]

Available at: <https://www.sprinklr.com/blog/online-reputation-management/>

[Accessed 10 8 2026].

avon, K., 2026. *vaultinum*. [Online]

Available at: <https://vaultinum.com/blog/enhancing-tech-due-diligence-with-network-footprinting>

[Accessed 10 8 2026].

Belisari, R., 2025. *rbconsultancy*. [Online]

Available at: <https://rbconsultancy ltd.co.uk/cyber-essentials-plus-fixing-windows-unquoted-service-path-vulnerability/>

[Accessed 9 8 2026].

Blumenthal, U., 2002. *rfc-editor*. [Online]

Available at: <https://www.rfc-editor.org/info/rfc3414/>

[Accessed 31 7 2026].

Borges, E., 2024. *recordedfuture*. [Online]

Available at: <https://www.recordedfuture.com/threat-intelligence-101/tools-and-techniques/banner-grabbing>

[Accessed 1 8 2026].

Cloudflare, 2026. *Cloudflare*. [Online]

Available at: <https://www.cloudflare.com/learning/email-security/dmarc-dkim-spf/>

[Accessed 29 7 2026].

Cucias, A., 2025. *blog.webhostmost*. [Online]

Available at: <https://blog.webhostmost.com/sftp-vs-ftp/>

[Accessed 2 8 2026].

Damodaran, A., 2015. *springer*. [Online]

Available at: <https://link.springer.com/article/10.1007/s11416-015-0261-z>

[Accessed 27 7 2026].

Dimitris, 2024. *hackthebox*. [Online]

Available at: <https://www.hackthebox.com/blog/malware-analysis-guide>

[Accessed 27 7 2026].

eccouncil, 2022. *eccouncil*. [Online]

Available at: <https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/what-are-sniffing-attacks/>

[Accessed 2 8 2026].

eccouncil, 2022. *eccouncil*. [Online]

Available at: <https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/basics-footprinting-reconnaissance/>

[Accessed 1 8 2026].

Edwards, S., 2022. *medium*. [Online]

Available at: <https://medium.com/@shaneedwards415/banner-grabbing-tools-techniques-a730fc312b11>

[Accessed 1 8 2026].

Freeborn, A., 2026. *tenable*. [Online]

Available at: <https://www.tenable.com/sc-report-templates/microsoft-windows-unquoted-service-path-vulnerability>

[Accessed 9 8 2026].

geeksforgeeks, 2025. *geeksforgeeks*. [Online]

Available at: <https://www.geeksforgeeks.org/ethical-hacking/static-malware-analysis/>

[Accessed 27 7 2026].

geeksforgeeks, 2025. *geeksforgeeks*. [Online]

Available at: <https://www.geeksforgeeks.org/ethical-hacking/what-is-banner-grabbing/>

[Accessed 1 8 2026].

geeksforgeeks, 2026. *geeksforgeeks*. [Online]

Available at: <https://www.geeksforgeeks.org/ethical-hacking/hashing-and-signatures-in->

static-malware-analysis/

[Accessed 27 7 2026].

Hanna, K. T., 2024. *techtarget*. [Online]

Available at: <https://www.techtarget.com/whatis/definition/Wireshark>

[Accessed 2 8 2026].

Harrington, D., 2022. *rfc-editor*. [Online]

Available at: <https://www.rfc-editor.org/info/rfc3411/>

[Accessed 31 7 2026].

Hegde, S. N., 2020. *redhat*. [Online]

Available at: <https://www.redhat.com/en/blog/introduction-wireshark>

[Accessed 2 8 2026].

Henry, M., 2026. *inmoment*. [Online]

Available at: <https://inmoment.com/blog/healthcare-reputation-management/>

[Accessed 10 8 2026].

Javelly, M., 2023. *cision*. [Online]

Available at: <https://www.cision.com/resources/insights/online-reputation-monitoring-tools/>

[Accessed 10 8 2026].

Kati, V., 2022. *mentionlytics*. [Online]

Available at: <https://www.mentionlytics.com/blog/review-monitoring/>

[Accessed 10 8 2026].

Kosinski, M., 2024. *ibm*. [Online]

Available at: <https://www.ibm.com/think/topics/spear-phishing>

[Accessed 29 7 2026].

Liford, J., 2013. *ryanandjeffshow*. [Online]

Available at: <http://www.ryanandjeffshow.com/blog/2013/04/05/the-microsoft-windows-unquoted-service-path-vulnerability/>

[Accessed 5 4 2026].

MadhukarRaina, 2026. *HTBacademy*. [Online]

Available at: <https://academy.hackthebox.com/course/preview/introduction-to-malware-analysis>

[Accessed 27 7 2026].

magnific, 2026. *magnific*. [Online]

Available at: https://www.magnific.com/free-vector/cyber-crime-isometric-illustration_6405908.htm#fromView=search&page=1&position=43&uuid=f4d382ae-5c7f-4333-ba1b-3075aae9abf8&track=ais_hybrid&query=Hospital+cyber+attack

[Accessed 10 8 2026].

NCSC, 2026. *NCSC*. [Online]

Available at: <https://www.ncsc.gov.uk/guidance/phishing>

[Accessed 29 7 2026].

nvd.nist, 2026. *nvd.nist*. [Online]

Available at: <https://nvd.nist.gov/vuln/detail/CVE-2019-20183>

[Accessed 30 7 2026].

okta, 2024. *okta*. [Online]

Available at: <https://www.okta.com/en-gb/identity-101/sniffing-attack/>

[Accessed 2 8 2026].

OxPablito, 2020. *Medium*. [Online]

Available at: <https://medium.com/@Pablo0xSantiago/cve-2019-20183-employee-records-system-bypass-file-upload-to-rce-ea2653660b34>

[Accessed 30 7 2026].

Presuhn, R., 2002. *rfc-editor*. [Online]

Available at: <https://www.rfc-editor.org/info/rfc3416/>

[Accessed 31 7 2026].

Presuhn, R., 2002. *rfc-editor*. [Online]

Available at: <https://www.rfc-editor.org/info/rfc3418/>

[Accessed 31 7 2026].

Rocca, D., 2024. *eaglepubs*. [Online]

Available at:

<https://eaglepubs.erau.edu/masteringenterprisenetworkslabs2edition/chapter/banner-grabbing/>

[Accessed 1 8 2026].

Schoenwaelder, J., 2008. *rfc-editor*. [Online]

Available at: <https://www.rfc-editor.org/info/rfc5343/>

[Accessed 31 7 2026].

ScienceDirect, 2014. *ScienceDirect*. [Online]

Available at: <https://www.sciencedirect.com/science/article/pii/S1877050915002136>

[Accessed 27 7 2027].

securityscorecard, 2025. *securityscorecard*. [Online]

Available at: <https://securityscorecard.com/blog/ftp-security-risks/>

[Accessed 2 8 2026].

sencode, 2026. *sencode*. [Online]

Available at: <https://sencode.co.uk/glossary/footprinting/>

[Accessed 10 8 2026].

SentinelOne, 2026. *SentinelOne*. [Online]

Available at: <https://www.sentinelone.com/cybersecurity-101/threat-intelligence/spear-phishing/>

[Accessed 29 7 2026].

Sharma, V., 2026. *birdeye*. [Online]

Available at: <https://birdeye.com/blog/healthcare-reputation-management/>

[Accessed 10 8 2026].

Shinde, S., 2025. *emeritus*. [Online]

Available at: <https://emeritus.org/blog/cybersecurity-banner-grabbing/>

[Accessed 1 8 2026].

sophos, 2026. *sophos*. [Online]

Available at: <https://www.sophos.com/en-us/cybersecurity-explained/wireshark>

[Accessed 2 8 2026].

staff, T. M., 2026. *trendmicro*. [Online]

Available at: https://www.trendmicro.com/en_gb/what-is/attack-surface/attack-surface-management.html

[Accessed 10 8 2026].

sysdig, 2026. *sysdig*. [Online]

Available at: <https://www.sysdig.com/learn-cloud-native/what-is-wireshark>

[Accessed 2 8 2026].

talkwalker, 2024. *talkwalker*. [Online]

Available at: <https://www.talkwalker.com/blog/best-online-reputation-management-tools>

[Accessed 10 8 2026].

V., J., 2025. *jscape*. [Online]

Available at: <https://www.jscape.com/blog/countering-packet-sniffers-using-encrypted-ftp>

[Accessed 2 8 2026].

Verma, S., 2019. *medium*. [Online]

Available at: <https://medium.com/@SumitVerma101/windows-privilege-escalation-part-1-unquoted-service-path-c7a011a8d8ae>

[Accessed 9 8 2026].

Waterman, M., 2023. <https://michaelwaterman.nl/2023/02/06/unquoted-service-path-privilege-escalation/>. [Online]

Available at: <https://michaelwaterman.nl/2023/02/06/unquoted-service-path-privilege-escalation/>

[Accessed 9 8 2026].

Worrall, A., 2025. *relias*. [Online]

Available at: <https://www.relias.com/blog/best-healthcare-reputation-management-software>

[Accessed 10 8 2026].

